

WEB APPLICATION PENETRATION TESTING REPORT

target System: testfire.net (Altoro Mutual Banking Application) Date of Assessment: May 18, 2026
Lead Penetration Tester: jubed mia Status: Complete

1.Executive Summary

During the comprehensive security evaluation of the testfire.net web application, a total of 7 vulnerabilities were uncovered. The application's core banking and authentication functions are significantly compromised. Serious design flaws allow unauthenticated attackers to bypass logins using basic SQL syntax, brute-force administrative accounts without protection, manipulate money transfers through HTTP requests, and unauthorizedly view other customers' transactions. Immediate remediation is required to safeguard user assets and data integrity.

2.Vulnerability Risk Dashboard

Finding ID Vulnerability Name Severity Status VULN-01 SQL Injection (Authentication Bypass) Critical Unpatched VULN-02 Insecure Direct Object Reference (IDOR) High Unpatched VULN-03 Broken Access Control (Fund Transfer Manipulation) High Unpatched VULN-04 Reflected Cross-Site Scripting (XSS) High Unpatched VULN-05 Weak Authentication & Insufficient Brute-Force Protection Medium Unpatched VULN-06 Sensitive Directory & File Enumeration Medium Unpatched VULN-07 Server Banner Grabbing & Information Disclosure Low Unpatched

Detailed Technical Findings

VULN-01: SQL Injection

Authentication Bypass)

Severity: Critical (CVSS v3.1: 9.8)

Affected Component:

Login Form (uid and passw parameters)

URL: <http://testfire.net>

Description:

The application constructs SQL queries by directly concatenating raw user input. This allows an attacker to inject logical SQL strings (e.g., ' or '1'='1) to manipulate query logic and authenticate as an administrative user without supplying a valid password.

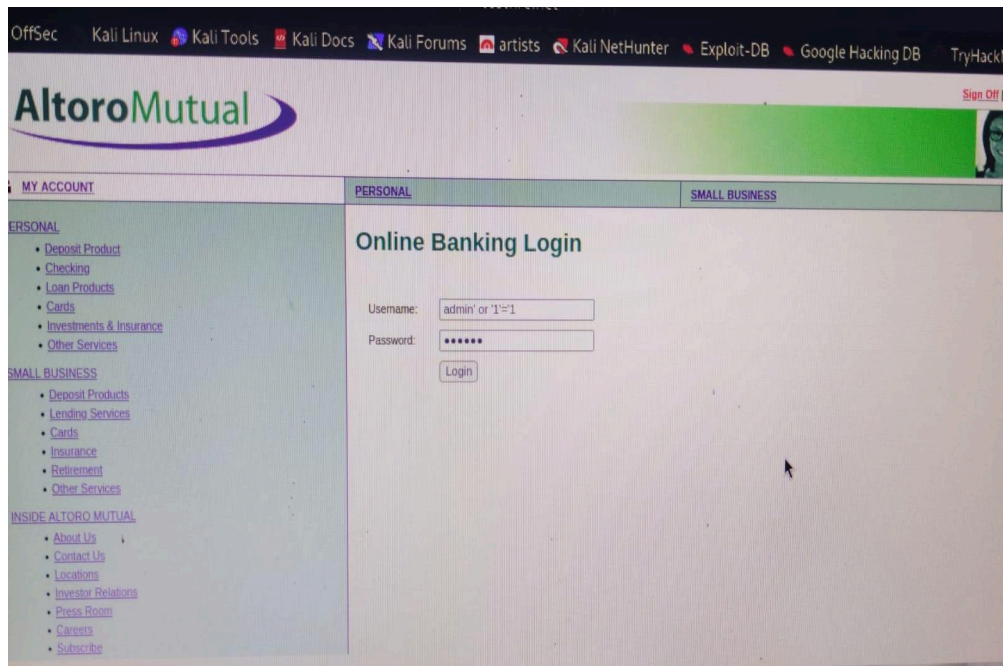
Proof of concept

1.The tester navigated to the Online Banking Login page.

2In the Username field, the following payload was entered: admin' or '1'='1

2.A dummy value was supplied in the Password field.

4. Upon submission, the database evaluated the statement as true, and the tester was successfully logged in as the "Admin User" (Hello Admin User).()



VULN-02: Insecure Direct Object Reference

Severity: High (CVSS v3.1: 8.5)

Affected Component: Account Summary Dashboard (acctId parameter)
URL: <http://testfire.net>

description:

The application relies entirely on user-controlled parameters (acctId) in the URL to fetch sensitive account history data. It lacks proper server-side validation to verify if the logged-in user actually owns the requested account ID

Proof of Concept (PoC):

1. Once logged into the dashboard, the default URL pointed to the tester's account ID (800000)
2. The tester manually modified the parameter in the browser's address bar to another target identifier (e.g., 800001 or 800002).
3. The server immediately rendered the private transaction histories, cookies, and balances belonging to different users without cross-checking authorization tokens.()

VULN-03: Broken Access Control (Fund Transfer Manipulation)

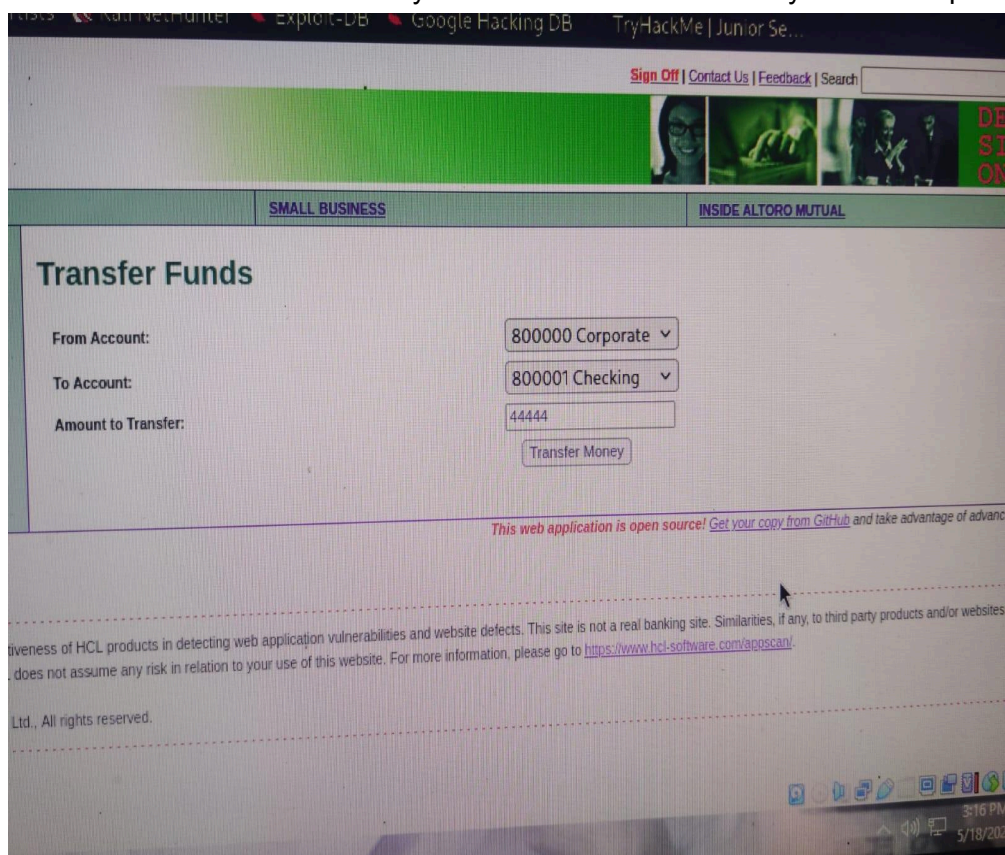
Severity: High (CVSS v3.1: 8.1)

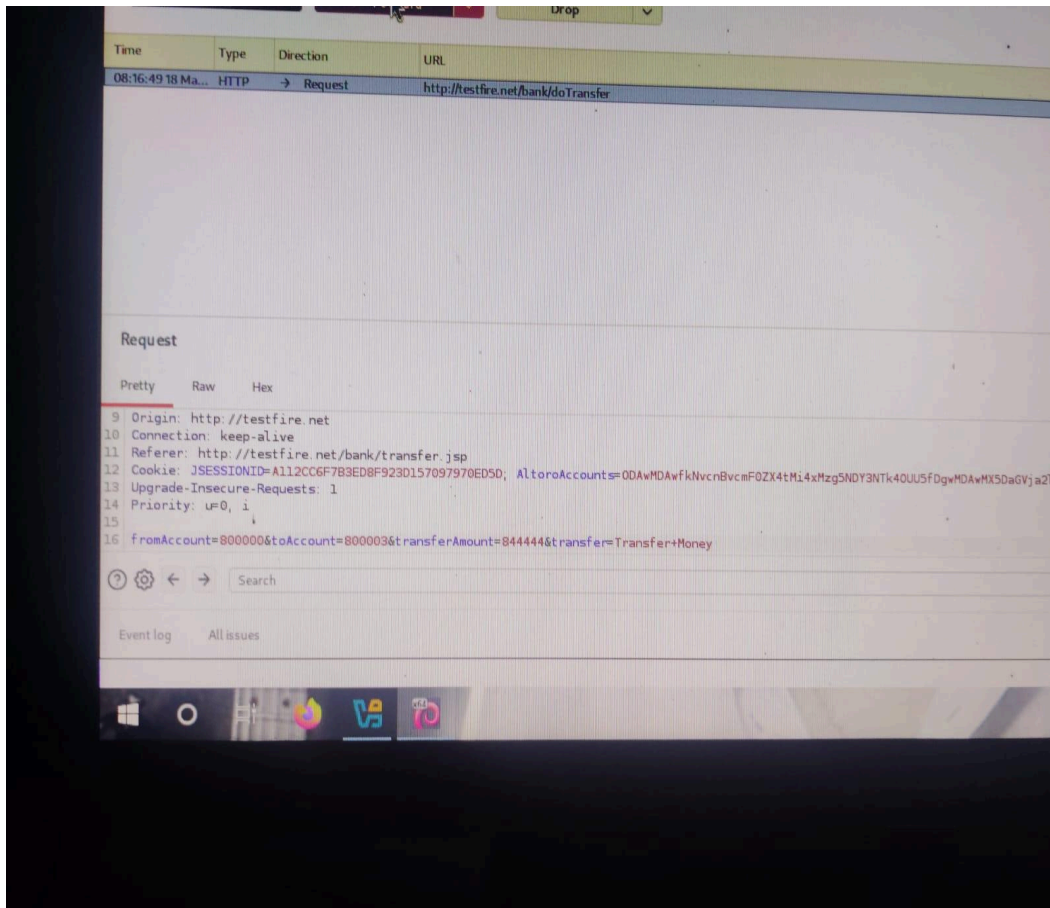
Affected Component: Fund Transfer API (fromAccount, toAccount, transferAmount parameters)

URL: <http://testfire.net>

Proof of concept

- 1.accounts or send customized currency figures).Proof of Concept (PoC):The tester initiated a legitimate transfer request within the web UI
- 2.The browser request was captured via Burp Suite Proxy (Intercept ON)
- 3.In the raw POST string, the toAccount value was altered from the initial input to an arbitrary account (800003), and the transferAmount was rewritten to a massive custom value (844444).
- 4.The modified packet was forwarded, and the web app returned a successful confirmation text: "844444.0 was successfully transferred..." based entirely on the tampered parameters.(





VULN-04: Reflected Cross-Site Scripting (XSS)

Severity: High (CVSS v3.1: 8.2) Affected Component: Global Search Box (query parameter)

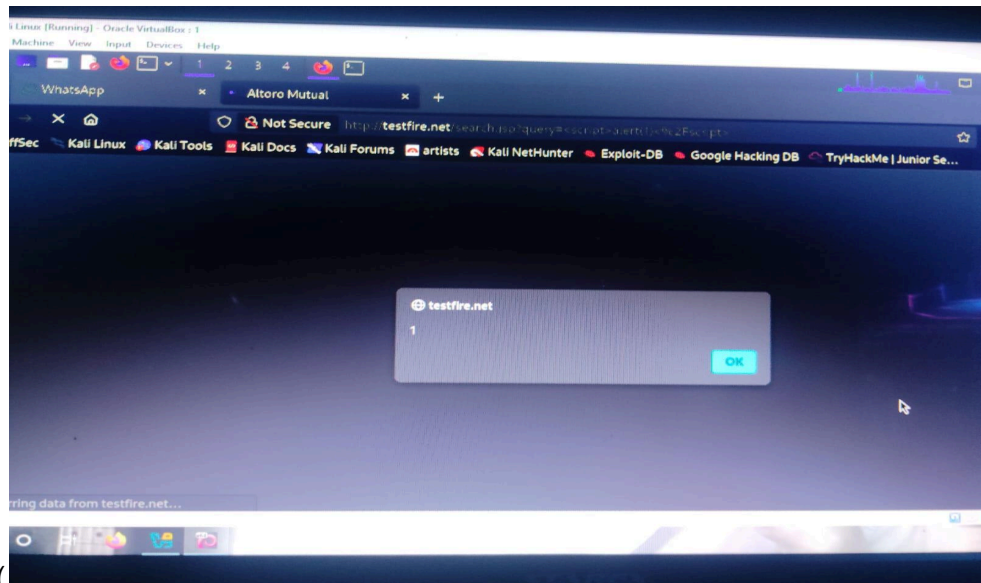
URL: <http://testfire.net>

Description:

The application reflects the user input back onto the web page context without validating or filtering out executable HTML/JavaScript tags

Proof of Concept (PoC): The tester inserted `<script>alert(1)</script>` inside the search input box

2..Upon submitting, the browser processed the unsanitized vector, throwing an alert popup



box showing 1.(

VULN-05: Weak Authentication & Insufficient Brute-Force Protection

Severity: Medium (CVSS v3.1: 5.3)

Affected Component: Login Workflow

URL: <http://testfire.net>

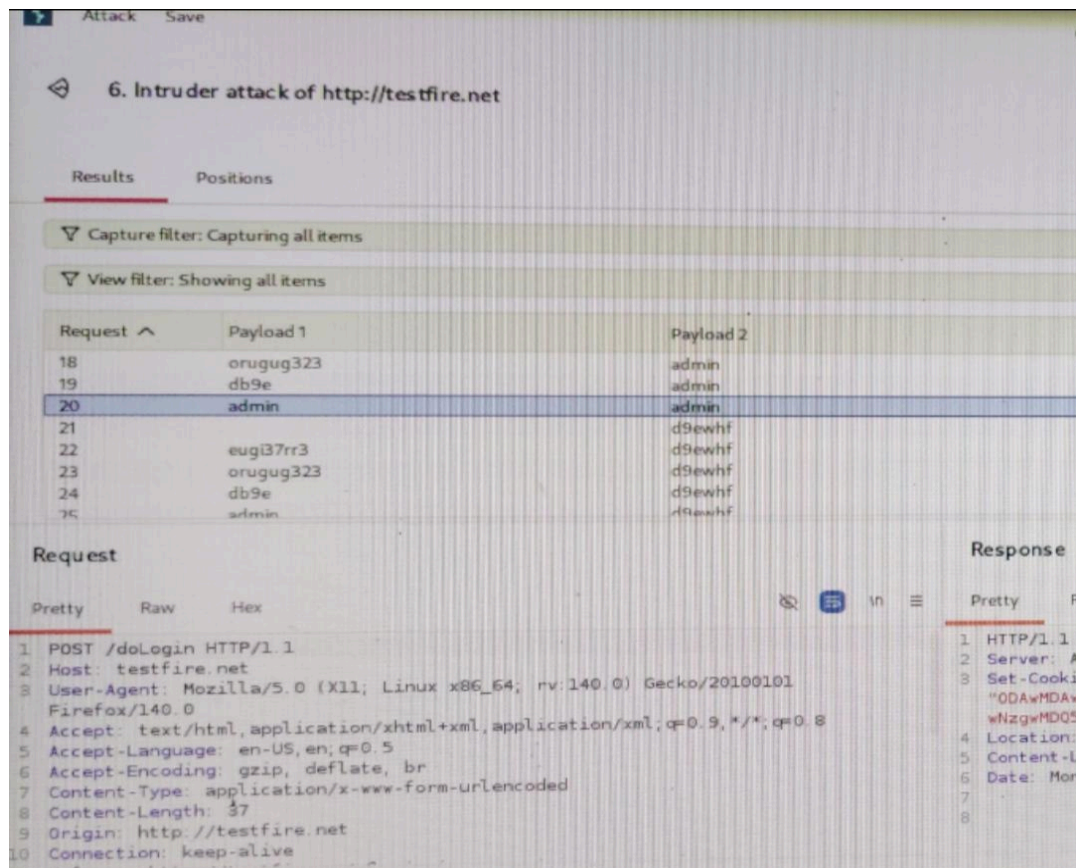
Description: The endpoint lacks anti-automation mechanisms (such as account lockouts, rate limiting, or CAPTCHA validation). This leaves the application susceptible to continuous credential stuffing and automated password guessing attacks

.Proof of Concept (PoC):

1The tester fed an authentication request into Burp Suite Intruder using a dictionary wordlist.

2.The tool automated hundreds of distinct login queries smoothly without incurring server blocks or rate-throttling limits

3..A successful response status (302 Redirect) easily separated valid structural targets (admin/admin) from failed attempts (200 OK responses)



VULN-06: Sensitive Directory & File Enumeration

Severity: Medium (CVSS v3.1: 5.3)Tool

Tool Used: Gobuster 3.8.2

Description:Using directory fuzzing against the root system layout, several private application paths were unmasked, facilitating a clear map of system workflows.

*Found Paths: /admin (302 Redirect), /bank (302 Redirect), and Windows device strings (com1, con) responding with 200 OK.(

```
Session Actions Edit View Help
emon6543@Emon: /  emon6543@Emon: /

[+] Url: http://testfire.net:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

admin (Status: 302) [Size: 0] [→ /login.jsp]
bank (Status: 302) [Size: 0] [→ /login.jsp]
com3 (Status: 200) [Size: 0]
com1 (Status: 200) [Size: 0]
com2 (Status: 200) [Size: 0]
con (Status: 200) [Size: 0]
images (Status: 302) [Size: 0] [→ /images/]
lpt1 (Status: 200) [Size: 0]
lpt2 (Status: 200) [Size: 0]
nul (Status: 200) [Size: 0]
pr (Status: 302) [Size: 0] [→ /pr/]
prn (Status: 200) [Size: 0]
static (Status: 302) [Size: 0] [→ /static/]
util (Status: 302) [Size: 0] [→ /util/]
Progress: 4613 / 4613 (100.00%)

Finished

(emon6543@Emon)-[/]
```

VULN-07: Server Banner Grabbing & Information Disclosure

Severity: Low (CVSS v3.1: 3.7)

Tool Used: Nmap 7.99

Description: The server responds to passive scan queries by leaking its exact software versions, aiding attackers in hunting down zero-days or public CVE records

```
(emon6543@Emon)-[~]
$ nmap -sV -p 80,443, testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-18 07:04 -0400
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.29s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache Tomcat/Coyote JSP engine 1.1
443/tcp   open  ssl/http Apache Tomcat/Coyote JSP engine 1.1

Service detection performed. Please report any incorrect results at https://
Nmap done: 1 IP address (1 host up) scanned in 20.41 seconds
```

Affected Ports: 80/tcp and 443/tcp running outdated Apache Tomcat/Coyote JSP engine 1.1

4. Comprehensive Remediation Matrix

1.Fixing VULN-01 (SQL Injection): Use Parameterized Queries (Prepared Statements)
across all login and database operations. Never concatenate strings to build raw SQL scripts.

2.Fixing VULN-02 & VULN-03 (IDOR & Access Control):
Enforce strict server-side Access Control Lists (ACL). Ensure that the session cookie identity matches the ownership records of the acctId or fromAccount parameter being called.

3.Fixing VULN-04 (XSS): Implement context-aware context encoding for all user-supplied data prior to rendering them within HTML templates

4..Fixing VULN-05 (Brute-Force): Implement multi-factor authentication (MFA), strict rate-limiting (e.g., maximum 5 failed attempts per IP/account per minute), and strong CAPTCHA verification challenges on public-facing gateways.

Report Authorization Signature:Prepared by: JUBED MIA (Information Security Consultant